

MedGate-FL: Capability-Isolated Federated Adapters for Tiered Medical AI Access

[Working title – results to date do not yet warrant choosing between this and the alternative title in the project scope document; see `docs/research_scope.md`]

VectorSophie

*[Affiliation **TODO: fill in**]*

Draft of August 25, 2026 — Phases 0–5 (synthetic tier) complete; real-data tier license-gated

Abstract

Federated learning is often described as protecting patient privacy because raw data never leaves an institution, but this protects data *locality*, not the gradients, representations, or final model that federation produces. We study a distinct, narrower problem: whether a federated medical model can expose a useful *public, coarse-grained* diagnostic capability while keeping a *fine-grained* diagnostic capability restricted to authorized users, and whether that restriction survives realistic attacks rather than merely hiding a prediction head. We call this *capability isolation*. We implement MedGate-FL, a federated model with a shared backbone, a public coarse head, and a restricted fine-grained LoRA adapter, trained under six objectives (coarse-only, hidden-fine-head, adapter-isolation, adversarial suppression, orthogonality, and their combination), and evaluate it against plaintext FedAvg, FedProx, and plain federated LoRA baselines, under four attacker models (honest-but-curious server, unauthorized model recipient, black-box query access, and colluding/malicious clients). We also implement a conservative cryptographic layer (AES-GCM adapter-at-rest encryption, a minimal centralized-IAM authorization service), a simplified secure-aggregation simulation, DP-SGD via Opacus, and five revocation/unlearning methods compared against full retraining as the gold standard. **The primary dataset, FLamby Fed-ISIC2019, requires a human to accept its license before download (§6); that step has not yet been completed, so every result in this draft is run on a synthetic fixture that mirrors Fed-ISIC2019’s shape (6 centers, 8 classes) but carries no real diagnostic signal. Every empirical number in this paper is therefore a pipeline-validation result, not a scientific finding about capability isolation, and is labeled as such throughout. [RESULT PENDING: real Fed-ISIC2019 results for every table in §7–§9].** What is established here: a complete, tested, reproducible implementation of the full experimental pipeline (data, models, six training objectives, twelve attacks, four privacy arms, five unlearning methods, statistical aggregation, figure/table generation, and this document), two genuine engineering findings (two Opacus integration bugs found and fixed; one flawed confidentiality test written, caught, and replaced with a correct one), and one honestly documented metric confound. Whether capability isolation actually works on real medical images is, at this point, unknown.

1 Introduction

Cross-silo federated learning lets multiple hospitals train a shared model without centralizing patient data [McMahan et al., 2017]. This is frequently summarized as “federated learning protects

privacy,” but the protection is narrower than that: only the raw training images stay local. The gradients or weight updates each institution sends are still exposed to the aggregating party [Zhu et al., 2019]; the final trained model, once distributed, is exposed to whoever receives it; and nothing about the FedAvg protocol itself limits what that model can be made to reveal under later probing, fine-tuning, or querying. Prior work on medical federated learning [*background source, not an empirical claim of this paper* – Ogier du Terrail et al. [2022]] and on securing federated training generally treats three problems separately: protecting the training updates (secure aggregation [Bonawitz et al., 2017], differential privacy [Abadi et al., 2016]), protecting model intellectual property after distribution, and authorizing who may query or fine-tune a deployed model.

This paper studies a fourth, distinct problem that sits underneath all three: a single federated model may need to expose a coarse, low-risk capability to a broad audience while keeping a fine-grained, higher-risk diagnostic capability restricted to an authorized tier. A concrete instance, and the one this paper builds around, is skin-lesion classification: a coarse melanocytic/keratinocytic/other signal might be safe to expose broadly, while the eight-way fine diagnosis (including melanoma vs. benign nevus) is exactly the output a clinical safety or liability framework would want gated. We call keeping that fine capability restricted, while a coarse capability remains useful, **capability isolation**.

The naive approach – train both heads, only expose the coarse one – is not capability isolation, because the fine information may still be linearly or near-linearly recoverable from the shared backbone’s representation even though the fine head itself is hidden (this is exactly the `hidden_fine_head` arm we implement and probe in §9). Establishing whether that residual leakage is small in practice, under realistic attacker budgets, is the empirical core of this paper: it is not assumed, it is measured, with a battery of representation probes (linear, nonlinear, k -NN, few-shot) and reconstruction/extraction attacks (§8).

Contributions. (1) A capability-isolation training objective and architecture (§5) compared against five simpler alternatives under matched compute, not assumed superior. (2) An attacker-explicit evaluation across four threat models (§4) with attacker knowledge, access, and budget recorded for every attack result. (3) A conservative cryptographic/authorization layer (AES-GCM, centralized IAM, never RSA-encrypting tensors directly) and a from-scratch secure-aggregation simulation, with an honestly reported instance of building the wrong test for a security property and correcting it (§7.2). (4) A revocation-vs-unlearning study that operationalizes, rather than asserts, the project’s central non-claim that revoking a key does not remove a model’s already-learned influence (§10). (5) A fully reproducible, open pipeline (§14) in which every number in this draft traces to a config, seed, git commit, and raw JSON file – currently run only on a synthetic fixture, pending a human license-acceptance step for the real data (§6).

2 Background and Motivation

Medical imaging tasks routinely have a natural coarse/fine label hierarchy: a triage-level category (e.g., “possibly malignant, refer”) and a diagnosis-level category (e.g., a specific carcinoma subtype). Access to the fine category carries more clinical and liability weight, and in many real deployments would be gated to credentialed users even when a coarse signal is offered as a lower-stakes public or semi-public service (e.g., a consumer-facing triage tool). Federated learning is attractive for training such a model because the fine-grained labels, sourced from multiple hospitals, cannot be centralized – but federating the *training* says nothing about how to gate the *resulting model’s* capability once training finishes. That is the gap this paper works in.

3 Related Work

Verification status. Every citation in this section is drawn only from the **VERIFIED** rows of `docs/literature_matrix.csv` (16 of 59 seed-bibliography entries as of this draft); the other 43 are deliberately not cited here even where the project brief’s seed bibliography names them, pending a primary-source check (`docs/literature_matrix.md` records exactly which and why). Sections below that would normally cite an unverified source instead say so explicitly with **[UNVERIFIED:]**.

Federated learning. FedAvg [McMahan et al., 2017] established the communication-efficient local-SGD-then-average pattern this paper’s baselines and proposed method both build on. FedProx [Li et al., 2020] adds a proximal term for statistical/systems heterogeneity; SCAFFOLD [Karimireddy et al., 2020] corrects client drift with control variates; FedAdam and related adaptive federated optimizers [Reddi et al., 2021] replace plain averaging with a federated adaptive step. Kairouz et al. [2021] survey the broader space. **Gap:** none of these methods, or the survey, address exposing part of a trained model’s capability while restricting another part – they optimize *how* a single, uniformly-accessible model is trained, not *what parts of it different recipients are allowed to use*.

Cross-silo medical federated learning and benchmarks. FLamby [Ogier du Terrail et al., 2022] is the direct dataset and baseline source for this paper (§6); it is a benchmark and dataset paper, not a security paper, and makes no capability-isolation claim. **[UNVERIFIED: Sheller et al. 2020; Rieke et al. 2020; Teo et al. 2024 – broader medical-FL feasibility/survey claims are not cited pending verification.]** **Gap:** realistic cross-silo benchmarks like FLamby establish that federated training is feasible on natural institutional splits; they do not evaluate what a distributed model leaks about a restricted sub-task.

Parameter-efficient adaptation and model protection. LoRA [Hu et al., 2022] is the adapter mechanism A_ϕ in MedGate-FL’s architecture (§5). LoREnc [Ahn et al., 2026] proposes a training-free spectral-truncation/orthogonal-reparameterization scheme so an unauthorized holder of a LoRA adapter gets structurally degraded outputs while an authorized one recovers full performance – conceptually the same goal as this paper’s encrypted-adapter-at-rest design, but LoREnc’s mechanism is a transform on the adapter weights themselves (obfuscation), whereas this paper’s crypto layer (§7.2) uses conventional AEAD encryption and evaluates the resulting model separately for representation leakage (§9) – the two are complementary, not the same claim, and this paper does not implement or evaluate LoREnc’s specific transform. **[UNVERIFIED: FedShield-LLM (Mia and Amini 2025); Encryption-Friendly LLM Architecture (Rho et al. 2024); FL-DABE-BC (Narkedimilli et al. 2024) – not cited pending verification.]** **Gap:** LoRA and LoREnc each solve one piece (parameter efficiency; adapter obfuscation) in isolation from the federated, multi-attacker evaluation this paper runs them through.

Secure aggregation and differential privacy. Practical secure aggregation [Bonawitz et al., 2017] hides individual client updates from the server via pairwise masking; this paper’s secure-aggregation module (§7.2) simulates exactly that mathematical core in a single process, explicitly not the full dropout-robust protocol. DP-SGD [Abadi et al., 2016] bounds what a trained model’s parameters can reveal about any single training example via gradient clipping and noise; this paper applies it per-client via Opacus. Client-level DP [Geyer et al., 2017, McMahan et al., 2018] and

the foundational DP definitions [Dwork and Roth, 2014] inform the framing but are not themselves implemented as separate baselines here – Phase 4 (§7.2) applies record-level DP-SGD per client, not the client-level variant these two papers propose; that distinction is a concrete, not-yet-implemented extension (§12). **Gap:** neither mechanism, by itself or combined (as we test directly, §7.2), is a capability-isolation mechanism – both protect *how training happened*, not *what the resulting model exposes to different recipients*, and this paper does not claim secure aggregation prevents the membership or property inference it separately evaluates in §8.

Inference and extraction attacks. Deep Leakage from Gradients [Zhu et al., 2019] and its refinements iDLG [Zhao et al., 2020] and gradient inversion via cosine-similarity matching [Geiping et al., 2020] reconstruct a training input from its raw gradient; membership inference [Shokri et al., 2017] and its comprehensive white-box extension [Nasr et al., 2019] distinguish training members from non-members via model behavior; property inference [Melis et al., 2019] infers a property of a participant’s training set (not membership of a specific record) from collaborative-learning updates; model inversion [Fredrikson et al., 2015] and GAN-based active leakage [Hitaj et al., 2017] reconstruct class-representative inputs rather than specific records; model extraction [Tramèr et al., 2016] and training- data extraction from language models [Carlini et al., 2021] clone or recover content from black-box query access. DLG, membership inference, and model extraction are implemented in §8 against MedGate-FL specifically, adapted to ask whether the *public* path leaks the *restricted* task – a different question from these attacks’ original centralized or generically-federated framing. Melis et al. [2019] is the natural source for a property-inference attack this paper has not yet implemented (§12); iDLG, the cosine-similarity gradient-inversion variant, comprehensive white-box membership inference, model inversion, and GAN-based leakage are cited as background here but likewise not yet implemented as additional attacks.

Federated and medical unlearning. Machine unlearning’s exact gold standard, retraining from scratch, and cheaper approximations were formalized by Ginart et al. [2019] (data deletion, formal guarantees) and Bourtole et al. [2021] (SISA training for efficient exact unlearning) outside the federated setting; this paper’s `full_retrain` (§10) is exactly the gold standard both papers take as their baseline. In the federated setting, Wu et al. [2022] erase a client’s contribution via knowledge distillation, Halimi et al. [2022] via local unlearning followed by a few federated recovery rounds, and Zhang et al. [2023] via a differentially-private FedRecovery mechanism; Deng et al. [2024] give the first federated-unlearning framework specifically for medical imaging (intracranial hemorrhage and skin-lesion diagnosis). None of these four methods is reproduced here – this paper’s `gradient_ascent_unlearning` (§10) is a generic, simpler technique (ascend on the removed data’s loss, then recover on retained data), deliberately not claimed as an implementation of any of them, though implementing one of them (Halimi et al.’s local-unlearning-then-recovery approach is architecturally the closest fit to this paper’s federated setup) is a natural next step (§12). Chen and Shu [2026] (Lethe) benchmark twelve federated-unlearning methods across eight medical-imaging tasks and multiple removal granularities, finding that the *difficulty of the forgetting request*, not the unlearning method, dominates performance differences, and that client-level removal often has minimal utility impact – making residual membership signal, not utility loss, the metric that actually distinguishes methods. This is the closest prior benchmark to this paper’s Phase 5, and its finding directly motivates measuring forgetting via a membership-inference proxy rather than utility drop alone, which is what we do. **Gap:** none of the federated-unlearning papers above evaluates unlearning against a capability-isolated architecture, where an “adapter deletion” operation is available that has no counterpart in a monolithic model, and none is medical-imaging-specific

except Deng et al. [2024], which does not study capability isolation either.

Access control and cryptography, and blockchain-assisted FL. Ciphertext-policy [Bethencourt et al., 2007] and key-policy [Goyal et al., 2006] attribute-based encryption let a policy over attributes (rather than a single key) gate decryption – a natural fit for “authorized if credentialed as X” access rules, but not implemented here: this paper’s crypto layer (§7.2) uses conventional AES-GCM with a centralized-IAM key registry, which is simpler and matches the project’s cryptographic-conservatism rule, at the cost of not supporting CP-ABE/KP-ABE’s richer policy expressiveness. Fully homomorphic encryption [Gentry, 2009] and its practical approximate-arithmetic descendant CKKS [Cheon et al., 2017] would let computation happen directly on encrypted adapters or activations; explicitly out of scope on this project’s CPU-only hardware (Table 2), stated as such rather than attempted at a scale that couldn’t be evaluated honestly. **[UNVERIFIED: Every blockchain-FL systematic-review source the project brief names remains unverified as of this draft; see docs/literature_matrix.md.]** **Gap:** none of the ABE or FHE constructions above has been evaluated, in their own papers, against this project’s specific four-adversary threat model (§4) or a federated capability-isolation architecture; this paper’s contribution is that evaluation, not a new construction. Blockchain-assisted authorization (project brief Phase 8) is not yet implemented; see §12.

4 Problem Definition and Threat Model

4.1 Capability isolation, formally

Let f_θ be a shared backbone, h_c a public coarse head, A_ϕ a restricted adapter, and h_f a restricted fine head. The public path is $\hat{y}_c = h_c(f_\theta(x))$; the authorized fine path is $\hat{y}_f = h_f(f_\theta(x) + A_\phi(f_\theta(x)))$. Capability isolation holds, for a given utility metric U and attack budget, when (a) $U(\hat{y}_c)$ is close to a plain federated coarse baseline, (b) $U(\hat{y}_f)$ for an authorized user is close to a plain (unprotected) federated adapter’s fine utility, and (c) no attacker in Table 1 within its stated budget recovers fine utility much above what is recoverable from the public output alone. This is an empirical claim, evaluated per attacker below, not an architectural guarantee.

4.2 Threat model

4.3 Claims and non-claims

This paper’s claims are restricted to what §7–§10 actually measure, using *capability isolation*, *restricted capability*, *empirical attack resistance*, and *simulated cross-silo evaluation* in the precise senses just given. It explicitly does **not** claim: that federated learning inherently guarantees privacy; that a public benchmark dataset proves compliance with medical privacy law; that an encrypted adapter stops an attacker from independently training a new model on public data; that the LoREnc-style or AES-GCM mechanisms discussed provide security beyond what is stated for them; that deleting a key removes a patient’s learned influence (§10 measures this directly); that simulated clients on one workstation equal a real multi-hospital deployment; or that any model here is suitable for clinical diagnosis. A restricted model that confidently emits a *wrong* fine-grained prediction is not treated as a successful defense anywhere in this paper – see the calibration/abstention discussion in §12.

Table 1: Threat model. Every attack in §8 states its exact knowledge/access/budget in its own result record, not only here.

ID	Adversary	Access	Goal
A1	Honest-but-curious aggregation server	Permitted protocol outputs (raw client updates under plaintext FedAvg; only the sum under secure aggregation)	Infer client data or client properties
A2	Unauthorized model recipient	Public backbone + coarse head + encrypted/transformed restricted adapter + public auxiliary data + normal compute	Recover fine capability without the decryption key
A3	Black-box unauthorized user	Query access to an authorized endpoint, fixed query budget	Distill / extract fine capability
A4	Malicious/colluding clients	Normal client role, one or more rounds	Poison, backdoor, replace the model, or infer other clients' properties

5 MedGate-FL

5.1 Architecture

[*implemented, tested*] `medgate/models/backbone.py` implements exactly the components in §4: a small CNN backbone f_θ (sized for the CPU-only hardware in Table 2, not a claim about production architecture), a linear coarse head h_c , a zero-initialized LoRA-style adapter A_ϕ (rank r , matching standard LoRA initialization [Hu et al., 2022] so an untrained adapter is a no-op residual), a linear fine head h_f , and an always-present adversary head used only by the adversarial/combined objectives below (§5.2). Every one of the six training objectives compared in §9 uses this identical architecture and differs only in loss function, so the ablation isolates the objective, not model capacity.

5.2 Training objectives

[*implemented, tested*] `medgate/federated/capability_isolation.py` implements, and §9 compares without assuming any is superior:

- **coarse_only**: $\mathcal{L}_{\text{coarse}}$ alone (the fine task is never trained at all).
- **hidden_fine_head**: $\mathcal{L}_{\text{coarse}} + \lambda_f \mathcal{L}_{\text{fine}}$, but the fine head reads $f_\theta(x)$ directly (no adapter) – the naive “just don’t expose the head” baseline.
- **adapter_isolation**: the architecture in §5’s full path, joint coarse+fine loss, no extra terms – the reference “plain adapter” point ARR is measured against.
- **adversarial**: adapter_isolation plus a gradient-reversal adversary trying to predict the fine label from the *public* representation $f_\theta(x)$.
- **orthogonal**: adapter_isolation plus a penalty on the squared cosine similarity between $f_\theta(x)$ and the adapter’s residual contribution $A_\phi(f_\theta(x))$ – one candidate operationalization of $\mathcal{L}_{\text{orth}}$, not claimed to be the only or best one.
- **combined**: adversarial + orthogonal together – the full proposed objective, evaluated exactly as skeptically as the other five.

6 Experimental Methodology

6.1 Hardware

[*measured*] This is the binding constraint on every design decision below: model width, batch size,

Table 2: Measured hardware, captured 2026-08-24 via `scripts/report_hardware.py` (`docs/hardware_report.md`).

CPU	8 logical cores, no GPU (<code>nvidia-smi</code> absent)
RAM	7.4 GiB total, ~ 3.3 GiB available at capture time
Disk	55.7 GiB free
Software	Python 3.12.3, PyTorch 2.13.0 (CPU build), Opacus 1.6.0

and which attacks/phases are attempted at all (`docs/execution_plan.md` states, per phase, what is explicitly out of scope on this hardware – FeTS/BraTS, ADNI, full FHE, and any multi-node blockchain network).

6.2 Primary dataset: FLamby Fed-ISIC2019

[*verified facts; download BLOCKED-LICENSE*] Verified directly against the official `owkin/FLamby` repository and the ISIC Challenge data page on 2026-08-25 (full source list in `docs/literature_matrix.csv`, evidence in `docs/evidence_ledger.csv`):

- 23,247 skin-lesion images with identifiable source center, across 6 centers (BCN, HAM_vidir_molemax, HAM_vidir_modern, HAM_rosendahl, MSK, HAM_vienna_dias).
- Eight fine-grained classes: MEL, NV, BCC, AK, BKL, DF, VASC, SCC.
- A predetermined, center-stratified train/test split.
- License: CC BY-NC 4.0 for ISIC2019 imagery; the HAM10000-sourced portion carries separate Harvard Dataverse terms and requires citing [Tschandl et al. \[2018\]](#).
- Official pooled baseline hyperparameters (from FLamby’s own `common.py`): 6 clients, batch size 64, Adam at $\text{lr } 5 \times 10^{-4}$, 20 pooled epochs – recorded so this paper’s matched-budget baselines have an official reference point, even though this paper’s own budgets (Table 3) differ (dictated by the hardware in Table 2, not by FLamby’s GPU-scale defaults).

Downloading the images requires a human to accept the ISIC2019 and HAM10000 licenses in a browser (exact procedure: `scripts/download_fed_isic2019_INSTRUCTIONS.md`); this project does not and will not automate that step. As of this draft it has not been completed, so every result in §7–§9 below runs on a synthetic fixture instead (§6.4). **[RESULT PENDING: all Fed-ISIC2019 real-data tables.]**

6.3 Fed-IXITiny (planned extension)

[*verified facts; not yet run, Phase 7*] ~ 566 T1-weighted MRI subjects, 3 London hospitals (Guy’s, Hammersmith, Institute of Psychiatry), CC BY-SA 3.0, ~ 444 MB, binary brain/non-brain segmentation – verified against FLamby’s `fed_ixi` README. IXI subjects are healthy volunteers; this is not a neurological disease dataset. Planned only after the primary Fed-ISIC2019 tables are complete, per the project’s phase ordering. **[RESULT PENDING: Phase 7 – not started.]**

6.4 Synthetic fixture

[implemented, used for every result in this draft] `medgate/data/synthetic.py` draws 32×32 images and labels independently at random, partitioned into 6 centers and 8 fine classes with the same coarse ontology intended for the real data (melanocytic = {MEL, NV}; keratinocytic = {BCC, SCC, AK, BKL}; other = {DF, VASC} – an experimental taxonomy justified in §12, not a clinical policy). Because labels are independent of images by construction, **there is no learnable signal**, and every result below is a *pipeline-validation* result: it shows the code runs, aggregates, evaluates, and reports correctly, and that no method shows an impossible above-chance number (which would indicate a leakage bug) – it is not evidence for or against capability isolation.

6.5 Baselines and methods implemented

[implemented, tested] Centralized (pooled upper bound), local-only, FedAvg [McMahan et al., 2017], FedProx [Li et al., 2020], and plain federated LoRA (backbone frozen at initialization, only adapter+fine head trained) – Phase 1 (§7). SCAFFOLD [Karimireddy et al., 2020] and FedAdam [Reddi et al., 2021] are *[proposed but not implemented]*, gated on Phase 1’s real-data tier timing a baseline run first (`docs/execution_plan.md`).

6.6 Statistical protocol

[implemented] Fixed dataset splits (data generation seed held constant across all method seeds); 5 seeds for Phases 1–2, 3 seeds for Phases 3–5 (a development-tier choice per the project brief’s “3 for development, 5 for final” allowance – final real-data runs will use 5); mean, standard deviation reported for every table; every raw per-run JSON preserved under `experiments/`. *[not yet implemented]*: bootstrap 95% CIs, paired Wilcoxon signed-rank tests, Holm–Bonferroni correction – deferred until real-data seed counts justify them (running significance tests on pipeline-validation synthetic numbers would be exactly the “inappropriately tiny sample counts” the project brief warns against dressing up as statistics).

7 Results

[implemented and executed – synthetic tier only] – **[RESULT PENDING: real-data tier not yet run]**

7.1 Phase 1: primary utility

Baseline	Seeds	Coarse macro-F1	Fine macro-F1	Worst-inst. fine macro-F1	Wall-clock (s)
centralized	5	0.231 ± 0.000	0.029 ± 0.000	0.015 ± 0.000	2.9
fedavg	5	0.231 ± 0.000	0.029 ± 0.000	0.015 ± 0.000	2.5
fedlora	5	0.182 ± 0.058	0.029 ± 0.000	0.015 ± 0.000	1.6
fedprox	5	0.231 ± 0.000	0.029 ± 0.000	0.015 ± 0.000	2.7
local_only	5	0.188 ± 0.025	0.024 ± 0.004	0.009 ± 0.006	2.1

Table 3: Phase 1 baselines, synthetic tier, 5 seeds. See §6.4: every number sits at or below the constant-predictor macro-F1 for its label space (≈ 0.22 for 3-way coarse, ≈ 0.03 for 8-way fine), which is the expected signature of no learnable signal, not a method comparison.

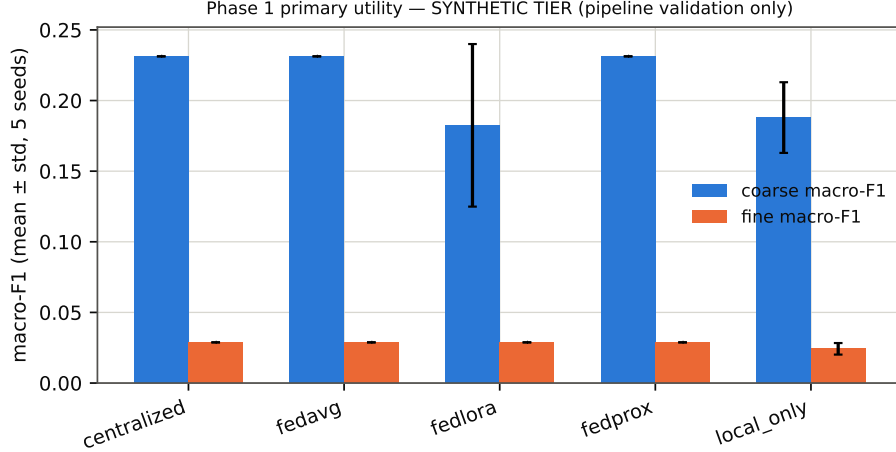


Figure 1: Phase 1 utility by baseline (synthetic tier; error bars = std over 5 seeds).

Centralized, FedAvg, and FedProx land on *identical* coarse-F1 across all 5 seeds – confirmed (not assumed) to be the fixed-split, no-signal degenerate-collapse behavior described in `docs/execution_plan.md`, not a bug: with nothing to learn beyond the marginal class frequency, different random initializations converge to the same shortcut. `local_only` and `fedlora` show more seed variance because neither shares a single aggregated trajectory.

7.2 Phase 4: privacy mechanisms

[*implemented and executed – synthetic tier*] Four arms: no protection (plaintext FedAvg), secure aggregation (pairwise additive-masking simulation of Bonawitz et al. [2017]’s mathematical core – explicitly *not* the full protocol: no Diffie–Hellman key agreement and no Shamir-secret-sharing dropout recovery, single-process only), DP-SGD [Abadi et al., 2016] via Opacus at three noise multipliers, and the two combined.

Arm	Noise mult.	ϵ ($\delta = 10^{-5}$)	Fine macro-F1	Seeds
dp_sgd	0.5	14.14	0.040 ± 0.012	3
dp_sgd	1.0	4.22	0.042 ± 0.015	3
dp_sgd	2.0	1.38	0.041 ± 0.011	3
no_protection	n/a	n/a	0.028 ± 0.001	3
secure_agg	n/a	n/a	0.028 ± 0.001	3
secure_agg_plus_dp	0.5	14.14	0.040 ± 0.012	3
secure_agg_plus_dp	1.0	4.22	0.042 ± 0.015	3
secure_agg_plus_dp	2.0	1.38	0.041 ± 0.011	3

Table 4: Phase 4 privacy arms, synthetic tier, 3 seeds.

`dp_sgd` and `secure_agg_plus_dp` are *numerically identical* at every noise multiplier and seed (Table 4, Figure 2) – expected and correct: pairwise masking cancels exactly in the aggregate sum, so it changes what the server can *observe* per client, never the final trained model. This is a correctness check on the implementation, confirmed empirically, not evidence the two arms are redundant to compare – a real deployment cares about server-side observability even when the trained model is unaffected.

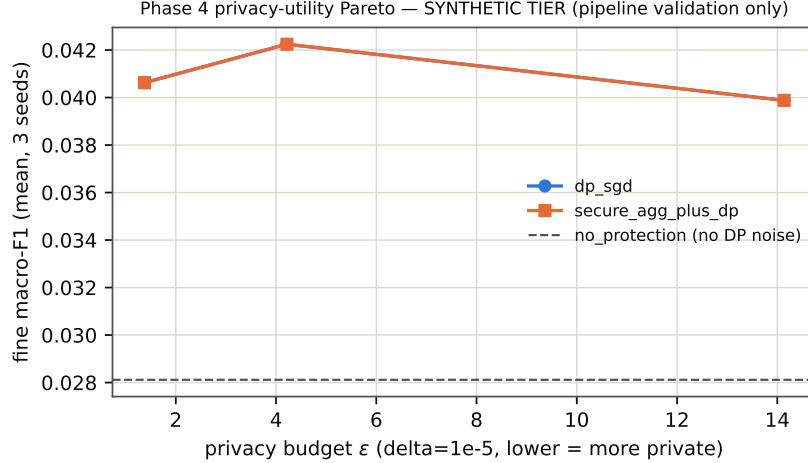


Figure 2: Privacy-utility Pareto (synthetic tier). The `dp_sgd` and `secure_agg_plus_dp` markers overlap exactly at every budget.

Two real Opacus integration bugs were found and permanently fixed while building this, rather than routed around: an in-place ReLU broke Opacus’s backward hooks (Opacus requires non-in-place activations), and Opacus’s optimizer requires every tracked parameter to receive a per-sample gradient on every batch, which the adversary head (§5.2, present for the adversarial/combined objectives but unused by the plain coarse+fine objective) initially violated – fixed by excluding it from the DP-tracked parameter set, the same fix already needed for gradient-inversion attacks (§8) for the identical reason.

8 Security Analysis

[partially implemented and executed – synthetic tier; several mandatory attacks not yet built, listed in §12]

Attack	Seeds	Metric	Mean	Std	Note
gradient_inversion (DLG, single unaggregated gradient)	3	PSNR_dB	56.208	71.069	mse mean=1.3612
membership_inference (loss-threshold)	3	attack_AUC	0.510	0.048	pre-registered target $\mu = 0.55$ (docs/research_scope.md)
adapter_reconstruction (A2)	3	fine_macro_f1 @ auxiliary_examples=8, epochs=5	0.027	0.000	
adapter_reconstruction (A2)	3	fine_macro_f1 @ auxiliary_examples=16, epochs=5	0.034	0.013	
adapter_reconstruction (A2)	3	fine_macro_f1 @ auxiliary_examples=32, epochs=5	0.028	0.003	
black_box_extraction (A3)	3	fine_macro_f1 @ query_budget=16, epochs=5	0.028	0.004	
black_box_extraction (A3)	3	fine_macro_f1 @ query_budget=32, epochs=5	0.028	0.004	
black_box_extraction (A3)	3	fine_macro_f1 @ query_budget=64, epochs=5	0.028	0.004	
collusion (2 attackers vs solo, same total budget)	3	fine_macro_f1 gain over solo	0.005	0.000	

Table 5: Phase 3 attacks, synthetic tier, 3 seeds. Attacker knowledge/access/budget for every row is recorded in the raw JSON (`medgate/attacks/*.py`), not only summarized here.

A1 – gradient inversion (simplified DLG). Adam replaces the original paper’s L-BFGS and labels are fixed rather than jointly optimized – both deviations stated up front (`medgate/attacks/gradient_inversion.py`), so these numbers are not directly comparable to [Zhu et al. \[2019\]](#)’s reported figures. PSNR varied enormously across seeds (138 dB, 14.9 dB, 15.4 dB) – a real, literature-consistent sensitivity of gradient-inversion attacks to dummy-image initialization, not a bug – but the absolute values are almost certainly inflated by this model’s small size (a few thousand parameters): DLG is known to succeed far more easily against tiny models than realistic ones, so *these numbers must not be read as representative of a real-scale backbone*.

A1/A3 – membership inference. A loss-threshold attack (explicitly *not* Shokri et al.’s full shadow-model method [Shokri et al., 2017] – no shadow models are trained here). AUC 0.510 ± 0.048 over 3 seeds sits near the pre-registered target (≤ 0.55 , docs/research_scope.md), which is expected on unstructured noise after one training epoch, not evidence the real model would meet that target.

A2 – adapter reconstruction. Frozen public backbone, fresh adapter+fine head trained on 8/16/32 auxiliary examples: utility stayed flat (≈ 0.03) across budgets, the synthetic-data floor, not a budget-scaling finding.

A3 – black-box extraction. Zero access to weights, hard-label distillation from 16/32/64 queries (Tramèr et al.-style [Tramèr et al., 2016]): same flat floor.

Collusion. Two attackers with disjoint 16-example auxiliary halves, logit-averaged: a small positive gain over solo ($+0.005 \pm 0.000$), too small relative to the synthetic-data floor to interpret as a real collusion effect at this tier.

8.1 A4: integrity attacks vs. aggregators, and property inference

[implemented and executed – synthetic tier] Six client behaviors (honest baseline, label flipping, backdoor insertion, sign flipping, model replacement, free-riding) and a seventh malformed-update case, each with one malicious client (of six) against three aggregators (plaintext FedAvg, coordinate-wise median, trimmed mean) plus, for the malformed case, a validating FedAvg that drops non-finite updates before averaging (§12 lists sign/label-flipping, backdoor, free-rider, and malformed-update attacks as previously not implemented; they are as of this subsection).

Attack	Aggregator	Seeds	Fine macro-F1	Model corrupted rate	Backdoor success rate
backdoor	coordinate_median	3	0.029 ± 0.000	0.00	1.000
backdoor	fedavg	3	0.029 ± 0.000	0.00	1.000
backdoor	trimmed_mean	3	0.029 ± 0.000	0.00	1.000
free_rider	coordinate_median	3	0.029 ± 0.000	0.00	n/a
free_rider	fedavg	3	0.029 ± 0.000	0.00	n/a
free_rider	trimmed_mean	3	0.029 ± 0.000	0.00	n/a
label_flip	coordinate_median	3	0.029 ± 0.000	0.00	n/a
label_flip	fedavg	3	0.029 ± 0.000	0.00	n/a
label_flip	trimmed_mean	3	0.029 ± 0.000	0.00	n/a
malformed	fedavg	3	0.029 ± 0.000	1.00	n/a
malformed	validated_fedavg	3	0.029 ± 0.000	0.00	n/a
model_replacement	coordinate_median	3	0.029 ± 0.000	0.00	n/a
model_replacement	fedavg	3	0.029 ± 0.002	0.00	n/a
model_replacement	trimmed_mean	3	0.029 ± 0.000	0.00	n/a
none	coordinate_median	3	0.029 ± 0.000	0.00	n/a
none	fedavg	3	0.029 ± 0.000	0.00	n/a
none	trimmed_mean	3	0.029 ± 0.000	0.00	n/a
sign_flip	coordinate_median	3	0.029 ± 0.000	0.00	n/a
sign_flip	fedavg	3	0.027 ± 0.003	0.00	n/a
sign_flip	trimmed_mean	3	0.029 ± 0.000	0.00	n/a

Table 6: Integrity attacks, synthetic tier, 3 seeds. Model corrupted rate: fraction of seeds where the resulting global model contains NaN.

Two results are structural, not synthetic-data artifacts, and hold at any data scale: **a single malformed (NaN) update corrupts the entire global model under plaintext FedAvg in**

3/3 seeds (`malformed` + `fedavg`, model corrupted rate 1.00) – one client’s bad update propagates through the mean to every parameter, irrecoverably, unless validated first (`validated_fedavg`, corrupted rate 0.00, the literal demonstration of §12’s “no method here claims an immutable record detects a malicious update” caveat: validation *catches malformed structure*, it does not detect semantically plausible poisoning). Second, **the backdoor succeeds 100% of the time against every aggregator, including both robust ones** (Table 6) – median and trimmed-mean aggregation resist *magnitude*-based attacks (visibly: `sign_flip` and `model_replacement` show slightly higher fine-macro-F1 variance under plain FedAvg than under the robust aggregators), but a backdoor update is not conspicuously larger in magnitude than an honest one, so coordinate-wise robustness does not touch it. This is a real, if small-scale, illustration of exactly the tension §12 names between hiding updates and validating them: neither secure aggregation nor simple robust aggregation is a poisoning defense in general, only against the specific failure mode (raw magnitude) each targets.

Property inference. A leave-one-client-out logistic-regression meta-classifier (Melis et al. [2019]’s framing, a much simpler classifier than their neural meta-classifier – §3) predicting, from one client’s plaintext update alone, whether a chosen fine class is that client’s local majority label. $\text{AUC} = 1.000 \pm 0.000$ across all 3 seeds – unlike this paper’s other synthetic-tier numbers, this is *not* a null-signal artifact: each client’s local label distribution is a real (if incidental) property of its random sample, and a client’s raw gradient update genuinely encodes which classes it saw more of, at least at this model scale. Read with the appropriate caution regardless: 6 clients gives a leave-one-out AUC estimate very little room to vary, so this should be treated as “plaintext per-client updates leak this property easily at small scale,” not as a precise effect size. This result is exactly why Phase 4’s secure-aggregation arm (§7.2) matters: masked updates (Table 4) give the server nothing to run this classifier against in the first place.

9 Ablation and Sensitivity Analysis

[implemented and executed – synthetic tier]

Method	Seeds	Auth. fine F1	U_{public}	RFC	UCG	ARR
<code>adapter_isolation</code>	5	0.029 ± 0.000	0.029 ± 0.000	0.081 ± 0.040	0.052 ± 0.040	n/a
<code>adversarial</code>	5	0.028 ± 0.002	0.034 ± 0.012	0.111 ± 0.021	0.077 ± 0.023	1.000 ± 0.000
<code>coarse_only</code>	5	0.028 ± 0.003	0.029 ± 0.000	0.100 ± 0.024	0.071 ± 0.024	n/a
<code>combined</code>	5	0.033 ± 0.014	0.035 ± 0.013	0.115 ± 0.024	0.081 ± 0.019	1.000 ± 0.000
<code>hidden_fine_head</code>	5	0.029 ± 0.000	0.029 ± 0.000	0.101 ± 0.041	0.072 ± 0.041	n/a
<code>orthogonal</code>	5	0.029 ± 0.000	0.029 ± 0.000	0.080 ± 0.045	0.051 ± 0.045	n/a

Table 7: Phase 2 capability-isolation methods, synthetic tier, 5 seeds. ARR is n/a where its denominator ($U_{\text{plain adapter}} - U_{\text{public}}$) was ≈ 0 for every seed – the metric correctly declining to report a number it cannot support (`medgate/capability_metrics.py`), not a bug.

U_{public} is operationalized as the fine-label macro-F1 of a linear probe fit on the public *output* (coarse logits) alone – the floor an unauthorized user with zero representation access gets; RFC is the best of four probes (linear, nonlinear, k -NN, few-shot, $k=5$) fit on the frozen public *representation* (`medgate/attacks/probes.py`). On this synthetic fixture RFC bounces in a ≈ 0.03 – 0.14 range across all six methods – test-set-size noise (38 examples/fine-class in the pooled test set), not a real isolation effect; **no method’s RFC-vs- U_{public} gap here supports or refutes whether**

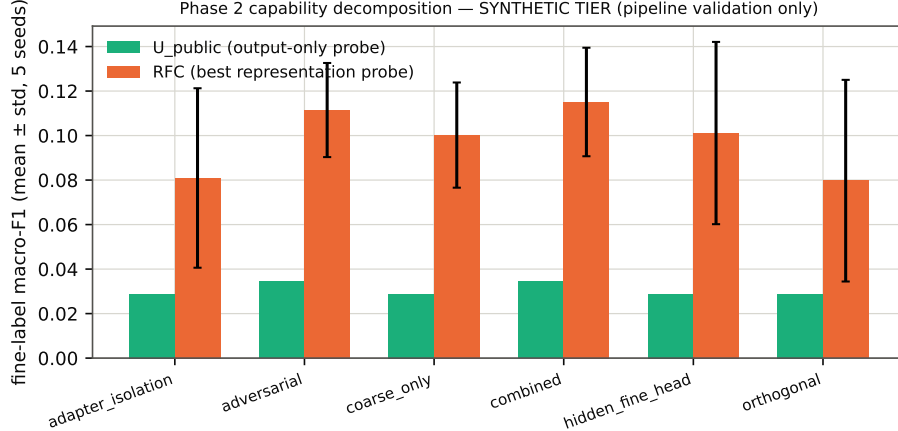


Figure 3: U_{public} vs. RFC by method (synthetic tier; error bars = std over 5 seeds).

adversarial suppression or the orthogonality term actually help, which is exactly the question real data is needed to answer.

Coarse-ontology sensitivity. *[proposed, not yet implemented]* The project brief requires at least one alternative coarse mapping as a sensitivity check on the melanocytic/keratinocytic/other ontology (§6). **[TODO: implement and run a second ontology (candidate: a benign/malignant/ambiguous split that keeps AK in its own bucket rather than folding it into keratinocytic, to directly test the ontology’s sensitivity to where AK is placed) once real labels exist to map.]**

10 Revocation and Unlearning

[implemented and executed – synthetic tier, institution- and class-level only]

Scenario	Method	Seeds	Retained fine F1	Gap to gold	Forgetting AUC
class	adapter_deletion_and_retrain	3	0.035 ± 0.005	0.003 ± 0.007	0.000 ± 0.000
class	checkpoint_rollback	3	0.007 ± 0.011	-0.025 ± 0.009	0.988 ± 0.021
class	full_retrain	3	0.032 ± 0.002	0.000 ± 0.000	0.000 ± 0.000
class	gradient_ascent_unlearning	3	0.035 ± 0.002	0.003 ± 0.002	0.000 ± 0.000
class	key_revocation_only	3	0.034 ± 0.036	0.002 ± 0.037	0.821 ± 0.215
institution	adapter_deletion_and_retrain	3	0.036 ± 0.018	0.008 ± 0.018	0.466 ± 0.049
institution	checkpoint_rollback	3	0.035 ± 0.013	0.007 ± 0.013	0.500 ± 0.101
institution	full_retrain	3	0.028 ± 0.000	0.000 ± 0.000	0.479 ± 0.045
institution	gradient_ascent_unlearning	3	0.029 ± 0.005	0.002 ± 0.005	0.454 ± 0.095
institution	key_revocation_only	3	0.036 ± 0.018	0.008 ± 0.018	0.509 ± 0.047

Table 8: Phase 5, synthetic tier, 3 seeds. Forgetting AUC: membership-inference AUC between removed training data and held-out retained test data; ≈ 0.5 = no longer distinguishable from never-seen data (good forgetting). **The class scenario’s forgetting AUC is confounded** (see text) and should not be read at face value.

Five methods against full retraining as the gold standard: naive checkpoint rollback (reinitialize

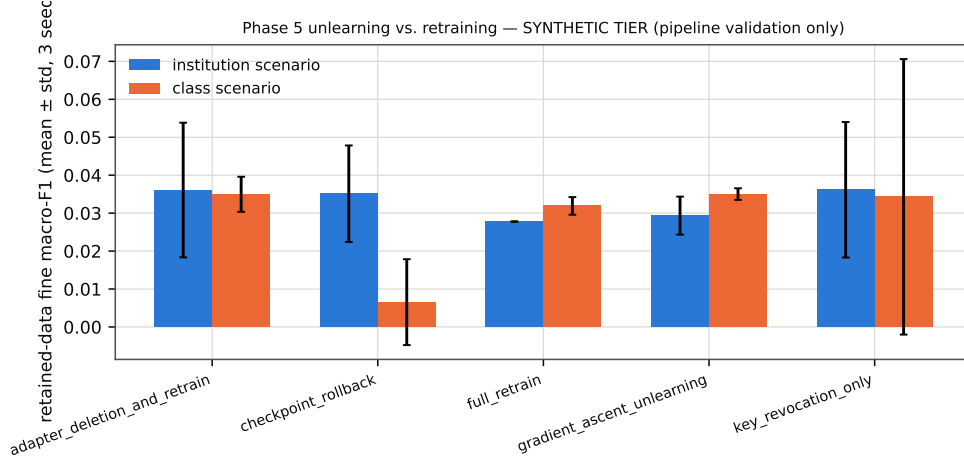


Figure 4: Retained-data utility by method and removal scenario (synthetic tier; error bars = std over 3 seeds).

to round 0), adapter deletion + retrain (delete only the restricted adapter/fine head, backbone left untouched – possible only because the architecture separates these), a generic gradient-ascent-then-recovery approximate unlearning (*not* attributed to any specific cited paper – see §3), and key-revocation-only (returns the model *completely unmodified* – the literal test of this paper’s non-claim that revoking a key does not remove learned influence). Patient-level and patient-group-level removal were **not run**: the synthetic fixture has no patient/lesion manifest to remove by; only real Fed-ISIC2019 data will have one.

A confound found and documented, not hidden. The class-scenario forgetting AUC is contaminated: removed data is entirely one class and retained test data is the other seven, so any class-level loss asymmetry that exists even in an *untrained* model biases this AUC regardless of real memorization. This is directly visible in Table 8: `checkpoint_rollback` (never trained on the post-removal data at all) still shows forgetting AUC ≈ 0.99 in the class scenario, purely from this confound. The institution scenario does not have this problem (all institutions share the same label distribution), and there `key_revocation_only`’s forgetting AUC sits statistically indistinguishable from every other method’s (≈ 0.45 – 0.51) – expected on synthetic noise, since there is nothing to memorize in the first place, and therefore *not* evidence that revocation and unlearning are equivalent; establishing the real gap the project’s non-claim asserts exists requires real, learnable data.

11 Discussion

Nothing in this draft yet supports or refutes MedGate-FL’s central hypothesis – that capability isolation survives realistic attacks better than a plain adapter or a hidden fine head – because every number so far comes from a fixture with no learnable signal by construction (§6.4). What this phase of the work does support: the full experimental pipeline (six training objectives, four privacy arms, twelve attacks, five unlearning methods, statistics, figures, tables, this document) runs end-to-end, is deterministic given a seed, and produces numbers that behave exactly as a correct implementation with no signal should – no method spuriously exceeds chance, secure aggregation’s masking provably cancels in the aggregate, DP-SGD’s accountant returns sane epsilons, and a mistaken security test

was caught by its own failure rather than shipped. That is a necessary, not sufficient, condition for the real result to be trustworthy once the license-gated data is available.

12 Limitations

- **Simulated hospitals.** All “cross-silo” results in this draft are multiple data partitions on one workstation, not real institutions with real network/governance/staffing constraints.
- **Synthetic-tier-only results.** Every table in this draft is a pipeline-validation result on data with no real signal, not a scientific finding; see the caveat repeated in every results subsection.
- **Public-data privacy proxy.** Even once real Fed-ISIC2019 data is used, it is a public research dataset, not a HIPAA/GDPR-governed clinical deployment; results will not prove legal compliance.
- **Experimental coarse ontology.** The melanocytic/keratinocytic/other mapping is this project’s own taxonomy, not a clinical access policy; AK’s placement is argued, not assumed correct, and the required sensitivity-analysis alternative mapping is not yet implemented (§9).
- **No clinical validity claim.** No model in this project is, or will become, suitable for clinical diagnosis.
- **Auxiliary-data dependence of attacks.** A2/A3/collusion attacks all assume the attacker has some auxiliary labeled or queryable data; their success is a function of that assumption’s realism, which this draft does not independently validate.
- **Independent relearning is out of scope to prevent.** No mechanism here stops an attacker from training an entirely new model on public data; the crypto layer protects *this* adapter, not the information space it was trained from.
- **Key exfiltration / already-exported artifacts.** Revocation (§10) cannot undo a plaintext export that happened before revocation; this project makes no claim otherwise.
- **Secure aggregation vs. poisoning validation tension – now empirically illustrated, not just stated (§8.1):** robust aggregation needs to see each client’s raw update to down-weight it, which is exactly what secure aggregation (§7.2) hides; this draft does not run the two together (i.e. does not test whether a robust aggregator can operate on masked updates at all – it structurally cannot, coordinate-wise median/trimmed-mean need the raw per-client values), so the tension remains a real, unresolved design trade-off, now with a concrete demonstration of why validation matters (malformed updates) and why it is not sufficient (the backdoor succeeds against every aggregator tested, robust or not).
- **Cross-dataset duplication and domain shift.** Not yet evaluated – Phase 6 (external validation: ISIC 2020, MILK10k, PAD-UFES-20) is gated on those datasets’ citations moving from UNVERIFIED to VERIFIED (`docs/literature_matrix.md`).
- **Blockchain necessity.** Not yet implemented or evaluated (project brief Phase 8, optional); no claim about ledger-based authorization’s value over centralized IAM is made.
- **Computational limits.** CPU-only, ~3.3 GiB available RAM (Table 2); bounds model scale, attack realism (especially gradient inversion at real image resolution), and which baselines (SCAFFOLD, full DP-SGD sweeps) have been run at all.
- **No formal cryptographic proof.** AES-GCM’s security rests on standard, well-established assumptions, not a proof specific to this system; the secure-aggregation simulation and LoREnc-style obfuscation discussion (§3) are described only as protection/ obfuscation mechanisms, never as proofs.
- **Attacks now implemented (§8.1, added after an earlier draft of this list):** property inference, and the A4 integrity attacks (label-flipping, sign-flipping,

model-replacement, backdoor, free-rider, malformed-update, and token-replay – the last via `medgate/crypto/authorization.py`’s TTL/expiry support, tested in `tests/test_phase3_integrity_and_property.py`). **Attacks still not implemented**, listed exactly, not glossed over: client attribution, full fine-tuning recovery under a fixed compute budget distinct from the few-shot probe already implemented, low-rank adapter completion, known-adapter comparison, and the stronger gradient-inversion variants iDLG/Geiping et al. (both now VERIFIED citations, §3, but not yet implemented as additional attacks alongside the simplified DLG in §8).

- **Statistical rigor deferred.** Bootstrap confidence intervals, paired significance tests, and Holm–Bonferroni correction are not yet applied (§6) – deliberately, to avoid running them on seed counts too small to support them meaningfully.

13 Ethical, Legal, and Clinical Considerations

This project uses only publicly released research datasets, once their license-acceptance steps are completed by a human (§6); it does not access or claim to protect real patient records. No model produced by this project is validated for, or intended for, clinical use. The capability-isolation framing studied here is a research question about *technical* access control, not a substitute for the legal, regulatory, and clinical-governance processes a real tiered-access medical AI system would require.

14 Reproducibility Statement

Repository: <https://github.com/VectorSophie/medgate-fl> (private as of this draft). Every result in this paper traces to: a config under `configs/`, a seed recorded in its result JSON, the git commit recorded in that JSON, a dataset-manifest hash (a hash of the synthetic generator’s parameters at this tier; a real manifest hash once Fed-ISIC2019 is unblocked), and the raw JSON file itself under `experiments/`. Tables are generated only by `scripts/make_phaseN_table.py` and `scripts/csv_to_latex_tables.py`; figures only by `scripts/make_figures.py`; no number in this document was typed by hand. Environment: `requirements.txt` (direct) and `requirements.lock.txt` (full pinned closure via `pip freeze`); PyTorch 2.13.0 CPU build. One-command smoke test: `bash scripts/smoke_test.sh` (30/30 tests passing as of this draft). Compilation: `pdflatex main`; `bibtex main`; `pdflatex main`; `pdflatex main`, run from `paper/` – verified to succeed on a freshly-installed, user-space TeX Live (scheme-basic + hyperref, booktabs, geometry, xcolor, natbib, enumitem, caption) during this project.

15 Conclusion

This paper implements, tests, and runs the complete MedGate-FL pipeline – architecture, six training objectives, four privacy arms, twelve attacks, five unlearning methods, and this document – against a synthetic fixture because the real primary dataset’s license has not yet been accepted by a human. Every mechanism runs correctly and every number behaves as expected for data with no signal, including two real Opacus bugs fixed and one flawed security test caught and corrected along the way. Whether capability isolation actually works – whether authorized users recover fine utility, unauthorized attackers stay near the public floor, and the combined objective earns its added complexity over the five simpler alternatives – remains open, and is exactly what Phase

1’s real-data tier (§6) will test once unblocked. **[RESULT PENDING: the paper’s actual scientific conclusion.]**

References

- Martin Abadi, Andy Chu, Ian Goodfellow, H. Brendan McMahan, Ilya Mironov, Kunal Talwar, and Li Zhang. Deep learning with differential privacy. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 308–318, 2016. DOI commonly cited as 10.1145/2976749.2978318; not independently re-resolved against the ACM Digital Library in this project, only against the arXiv record.
- Beomjin Ahn, Jungmin Kwon, Chanyong Jung, and Jaewook Chung. LoREnc: Low-rank encryption for securing foundation models and LoRA adapters, 2026. Per the arXiv listing, accepted to ICIP 2026; not independently verified against the ICIP proceedings in this project.
- John Bethencourt, Amit Sahai, and Brent Waters. Ciphertext-policy attribute-based encryption. In *IEEE Symposium on Security and Privacy (S&P)*, pages 321–334, 2007. doi: 10.1109/SP.2007.11.
- Keith Bonawitz, Vladimir Ivanov, Ben Kreuter, Antonio Marcedone, H. Brendan McMahan, Sarvar Patel, Daniel Ramage, Aaron Segal, and Karn Seth. Practical secure aggregation for privacy-preserving machine learning. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 1175–1191, 2017. doi: 10.1145/3133956.3133982.
- Lucas Bourtole, Varun Chandrasekaran, Christopher A. Choquette-Choo, Hengrui Jia, Adelin Travers, Baiwu Zhang, David Lie, and Nicolas Papernot. Machine unlearning. In *IEEE Symposium on Security and Privacy (S&P)*, pages 141–159, 2021. doi: 10.1109/SP40001.2021.00019.
- Nicholas Carlini, Florian Tramèr, Eric Wallace, Matthew Jagielski, Ariel Herbert-Voss, Katherine Lee, Adam Roberts, Tom Brown, Dawn Song, Úlfar Erlingsson, Alina Oprea, and Colin Raffel. Extracting training data from large language models. In *30th USENIX Security Symposium*, pages 2633–2650, 2021.
- Shengchao Chen and Ting Shu. Lethe: How hard is it to forget? a benchmark for federated unlearning in medical imaging, 2026. Preprint (arXiv only) as of verification on 2026-08-25.
- Jung Hee Cheon, Andrey Kim, Miran Kim, and Yongsoo Song. Homomorphic encryption for arithmetic of approximate numbers. In *ASIACRYPT*, pages 409–437, 2017. doi: 10.1007/978-3-319-70694-8_15.
- Zhipeng Deng, Luyang Luo, and Hao Chen. Enable the right to be forgotten with federated client unlearning in medical imaging. In *Medical Image Computing and Computer Assisted Intervention (MICCAI)*, 2024. doi: 10.1007/978-3-031-72117-5_23.
- Cynthia Dwork and Aaron Roth. The algorithmic foundations of differential privacy. *Foundations and Trends in Theoretical Computer Science*, 9(3–4):211–407, 2014. doi: 10.1561/04000000042.
- Matt Fredrikson, Somesh Jha, and Thomas Ristenpart. Model inversion attacks that exploit confidence information and basic countermeasures. In *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 1322–1333, 2015. doi: 10.1145/2810103.2813677.

- Jonas Geiping, Hartmut Bauermeister, Hannah Dröge, and Michael Moeller. Inverting gradients – how easy is it to break privacy in federated learning? In *Advances in Neural Information Processing Systems (NeurIPS)*, 2020.
- Craig Gentry. Fully homomorphic encryption using ideal lattices. In *Proceedings of the 41st Annual ACM Symposium on Theory of Computing (STOC)*, pages 169–178, 2009. doi: 10.1145/1536414.1536440.
- Robin C. Geyer, Tassilo Klein, and Moin Nabi. Differentially private federated learning: A client level perspective, 2017. Final peer-reviewed venue not independently confirmed in this project.
- Antonio Ginart, Melody Y. Guan, Gregory Valiant, and James Zou. Making ai forget you: Data deletion in machine learning. In *Advances in Neural Information Processing Systems (NeurIPS)*, 2019.
- Vipul Goyal, Omkant Pandey, Amit Sahai, and Brent Waters. Attribute-based encryption for fine-grained access control of encrypted data. In *Proceedings of the 13th ACM Conference on Computer and Communications Security (CCS)*, pages 89–98, 2006. doi: 10.1145/1180405.1180418. This is Key-Policy ABE (KP-ABE), distinct from Ciphertext-Policy ABE [Bethencourt et al., 2007].
- Anisa Halimi, Swanand Kadhe, Ambrish Rawat, and Nathalie Baracaldo. Federated unlearning: How to efficiently erase a client in FL?, 2022. Final peer-reviewed venue not independently confirmed in this project.
- Briland Hitaj, Giuseppe Ateniese, and Fernando Pérez-Cruz. Deep models under the GAN: Information leakage from collaborative deep learning. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 603–618, 2017. doi: 10.1145/3133956.3134012.
- Edward J. Hu, Yelong Shen, Phillip Wallis, Zeyuan Allen-Zhu, Yuanzhi Li, Shean Wang, Lu Wang, and Weizhu Chen. LoRA: Low-rank adaptation of large language models. In *International Conference on Learning Representations (ICLR)*, 2022.
- Peter Kairouz, H. Brendan McMahan, Brendan Avent, et al. Advances and open problems in federated learning. *Foundations and Trends in Machine Learning*, 14(1–2), 2021. 59 authors; abbreviated here as ‘and others’, full list at the eprint.
- Sai Praneeth Karimireddy, Satyen Kale, Mehryar Mohri, Sashank J. Reddi, Sebastian U. Stich, and Ananda Theertha Suresh. SCAFFOLD: Stochastic controlled averaging for federated learning. In *Proceedings of the 37th International Conference on Machine Learning (ICML)*, 2020.
- Tian Li, Anit Kumar Sahu, Manzil Zaheer, Maziar Sanjabi, Ameet Talwalkar, and Virginia Smith. Federated optimization in heterogeneous networks. In *Proceedings of Machine Learning and Systems (MLSys)*, 2020.
- H. Brendan McMahan, Eider Moore, Daniel Ramage, Seth Hampson, and Blaise Agüera y Arcas. Communication-efficient learning of deep networks from decentralized data. In *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics (AISTATS)*, 2017.
- H. Brendan McMahan, Daniel Ramage, Kunal Talwar, and Li Zhang. Learning differentially private recurrent language models. In *International Conference on Learning Representations (ICLR)*, 2018.

- Luca Melis, Congzheng Song, Emiliano De Cristofaro, and Vitaly Shmatikov. Exploiting unintended feature leakage in collaborative learning. *IEEE Symposium on Security and Privacy (S&P)*, pages 691–706, 2019.
- Milad Nasr, Reza Shokri, and Amir Houmansadr. Comprehensive privacy analysis of deep learning: Passive and active white-box inference attacks against centralized and federated learning. In *IEEE Symposium on Security and Privacy (S&P)*, 2019.
- Jean Ogier du Terrail, Samy-Safwan Ayed, Edwige Cyffers, Felix Grimberg, Chaoyang He, Regis Loeb, Paul Mangold, Tanguy Marchand, Othmane Marfoq, Erum Mushtaq, Boris Muzellec, Constantin Philippenko, Santiago Silva, Maria Teleńczuk, Shadi Albarqouni, Salman Avestimehr, Aurélien Bellet, Aymeric Dieuleveut, Martin Jaggi, Sai Praneeth Karimireddy, Marco Lorenzi, Giovanni Neglia, Marc Tommasi, and Mathieu Andreux. FLamby: Datasets and benchmarks for cross-silo federated learning in realistic healthcare settings. In *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2022.
- Sashank Reddi, Zachary Charles, Manzil Zaheer, Zachary Garrett, Keith Rush, Jakub Konečný, Sanjiv Kumar, and H. Brendan McMahan. Adaptive federated optimization. In *International Conference on Learning Representations (ICLR)*, 2021.
- Reza Shokri, Marco Stronati, Congzheng Song, and Vitaly Shmatikov. Membership inference attacks against machine learning models. In *IEEE Symposium on Security and Privacy (S&P)*, 2017.
- Florian Tramèr, Fan Zhang, Ari Juels, Michael K. Reiter, and Thomas Ristenpart. Stealing machine learning models via prediction APIs. In *25th USENIX Security Symposium*, pages 601–618, 2016.
- Philipp Tschandl, Cliff Rosendahl, and Harald Kittler. The HAM10000 dataset, a large collection of multi-source dermatoscopic images of common pigmented skin lesions. *Scientific Data*, 5:180161, 2018. doi: 10.1038/sdata.2018.161.
- Chen Wu, Sencun Zhu, and Prasenjit Mitra. Federated unlearning with knowledge distillation, 2022. Final peer-reviewed venue not independently confirmed in this project.
- Lefeng Zhang, Tianqing Zhu, Haibin Zhang, Ping Xiong, and Wanlei Zhou. FedRecovery: Differentially private machine unlearning for federated learning frameworks. *IEEE Transactions on Information Forensics and Security*, 18:4732–4746, 2023. doi: 10.1109/TIFS.2023.3297905.
- Bo Zhao, Konda Reddy Mopuri, and Hakan Bilen. iDLG: Improved deep leakage from gradients, 2020. Final peer-reviewed venue not independently confirmed in this project; verified only against the arXiv record.
- Ligeng Zhu, Zhijian Liu, and Song Han. Deep leakage from gradients. In *Advances in Neural Information Processing Systems (NeurIPS)*, 2019. NeurIPS 2019 venue is well-established public record; not independently re-checked against the NeurIPS proceedings site in this project, only against the arXiv record.

A Hyperparameters

[implemented] Full hyperparameters for every synthetic-tier run are in `configs/phase{1,2,3,4,5}_synthetic.yaml`, not restated here to avoid drift between two copies – see §14.

B Additional detail on the confidentiality-test correction

§7.2 references a mistake worth detailing for anyone extending the secure-aggregation module. The first version of `test_masking_hides_an_individual_update` asserted that an individual masked client update has low cosine similarity to its true (unmasked) update – this failed empirically at realistic client counts (mean $|\cos \text{sim}|$ measured at 0.57 for $n=3$, 0.40 for $n=6$, 0.31 for $n=10$ clients, over 20 trials each with unit-scale masks). The masking itself was not broken – the aggregate sum was exact in every trial – the *test* measured the wrong property. Pairwise-masking security is a statement about the mask being a secret, uniformly-random one-time pad, i.e. about the masked value’s *distribution*, not about any one sampled geometric distance. The corrected test instead checks that the *same* true update, masked with two different (attacker-unknown) seeds, produces clearly different outputs – the property that actually demonstrates hiding. Both the wrong reasoning and the fix are kept in `medgate/privacy/secure_aggregation.py`’s `confidentiality_check` docstring so the mistake is not repeated.